

RED LINE WALE QUESTION LAZMI KERNE HAIN

DEFINE INF SECURITY:

Protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

Three Pillars of Information Security:

- **Confidentiality:** keeping information secret
- **Integrity:** keeping information in its original form
- **Availability:** keeping information and information systems available for use
- **Bangladesh Bank SWIFT Hack – Feb 2016:** Hackers used SWIFT credentials of Bangladesh Central Bank employees to send **more than three dozen fraudulent money** transfer requests.
- Requests sent to the Federal Reserve Bank of New York asking the bank to transfer millions of the Bangladesh Bank's funds to bank accounts in the Philippines, Sri Lanka and other parts of Asia.

Stolen **amount was 81 USD**

- Total impact could have **been USD 1 billion**
- Pakistan ranked almost at **the bottom** of the table in international ranking by ITU Pak rank is **67th**
- Information **security is everyone's responsibility**
- Pakistan Cyber Security **Association (PCSA)** formed to address Pakistan's international ranking
- **Three pillars of information security:**
 - People
 - Process
 - Technology



Topic No 05: Who Are The Players In Information Security?

- **Government**
- Industry & sectors
- International organizations
- **Professional associations**
- Academia and research organizations
- Vendors and suppliers

- Government:

- Policy making
- Law enforcement
- Legal system
- National cyber security strategy and standards
- International coordination
- Computer Incident Response Team (CIRT)

Topic No 06: Infosec Transformation Framework 4 Layers

1. Security hardening
2. Vulnerability management
3. Security engineering
4. Security governance

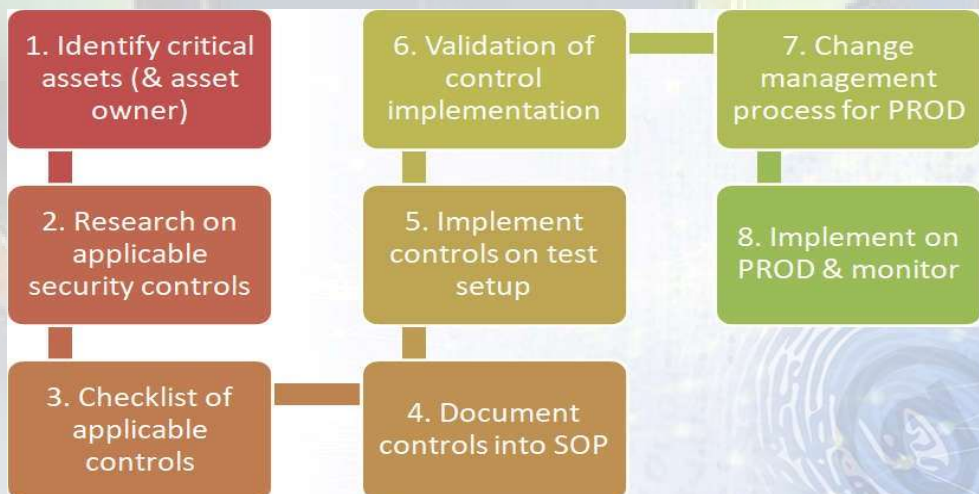


Security hardening:

- Compile IT assets
- Establish minimum security baseline (MSB)
- Research security controls and benchmarks
- Pilot (test)

5. **Security hardening** is the process of configuring IT assets to maximize security of the IT asset and minimize security risks

- **8 Step methodology for security hardening:** (Is k first step ko ache se daikh lena with detail. Detail aage bhe aye gi in shape of table) Baqi name sub k yad kerna very imp topic;



- Why is security hardening at the first step in the security transformation model?
 - Most basic security settings
 - If not adequately addressed here, rest of the security measures hardly matter

What is security Governance:

- Information security governance in simpler terms just means effective management of the security program.
- **ISO27001:2013 – ISMS (Information Security Management System)** is the world's leading and most widely adopted security governance standard
- **ISO27001** "provides a model for establishing, implementing, operating, monitoring, reviewing, maintaining and improving an information security management system."
- Ten short clauses and a long Annex with 114 controls in 14 groups
- **People, process, and technology** are together referred to as the Information Security Triad
- All three aspects help to form a holistic view of Information Security

This Question will in the form of table and it will mix all steps. You have to arrange this like I am writing here

Process	• User access management • Backups • Incident management • Change management • Vulnerability management
Technology	• Firewalls • Antivirus • Email anti-spam filtering solution • Web filtering solution • Data loss prevention (DLP) solution

- The **Information Security Manager** develops a policy to regulate the Information Security program which is **signed off by senior management**
- **InfoSec Manager Tasks: (Koi se 5 steps yad ker lena)**
 - Develop policy
 - Training & awareness
 - Design security architecture
 - Design security controls
 - Ensure controls are implemented
 - Conduct risk assessment
 - Conduct security testing
 - Monitor vulnerability management program
 - Facilitate incident management process

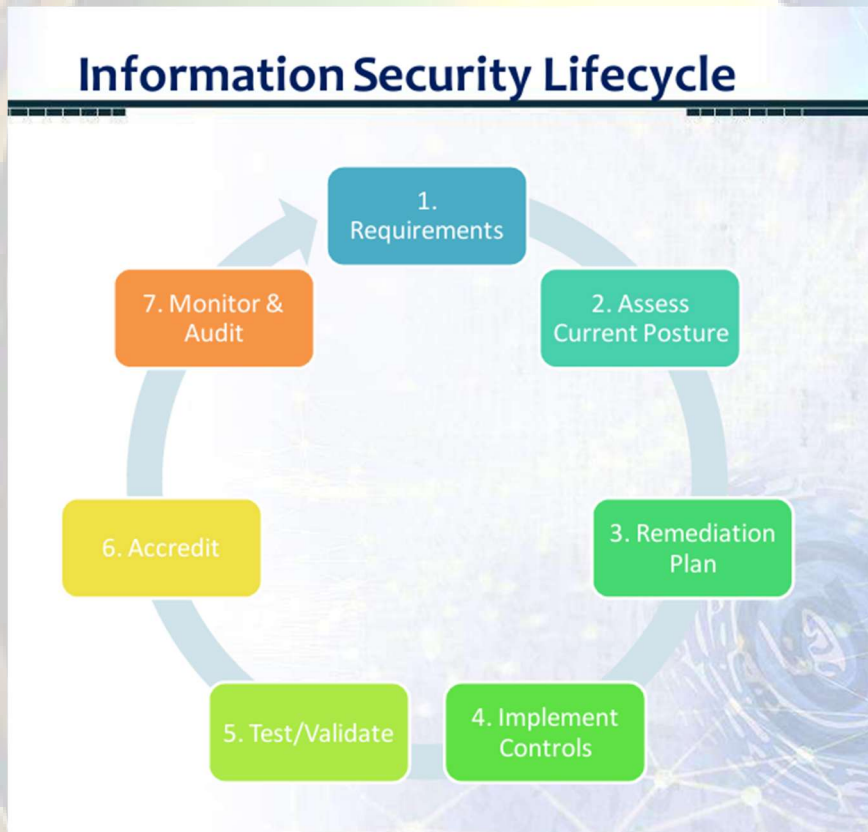
- Sign-off critical change management activities

Yeh tale given ho ga yeh mix ho ga isko aise arrange kerna ho ga:

Don'ts:	Share your password Click on suspicious email links Install unlicensed software on your PC
Do's:	Logout when getting up from your system Report security incidents

- **Risk Assessment:**

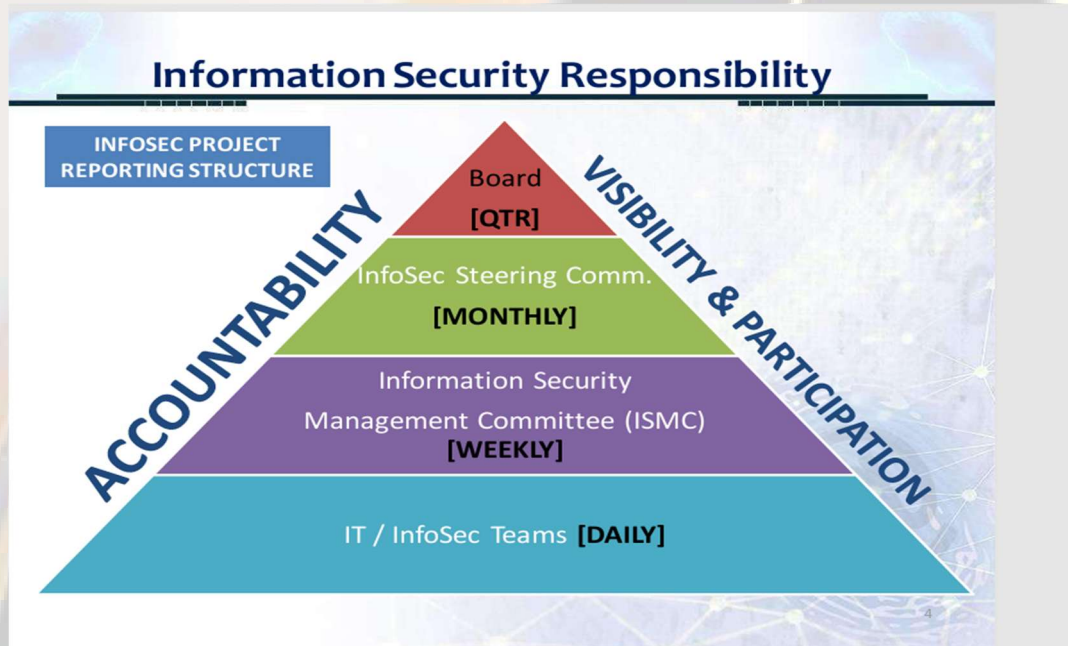
- Foundation for effective risk management
- Solid understanding of the risk universe
- Nature and extent of risk to IT resources and potential impact on organizations activities



- **: what is Security Accreditation define its steps**

- Review process has been followed (change management, SOP, sign-offs)
- Establish monitoring mechanism
- Awareness training
- Issue formal accreditation

This question will be in form of triangle or in form of table. You have to write answer in form of table. In one side responsible teams on other side reporting duration



Challenges Of InfoSec Implementation

• Challenges Of IT:

- Complex and difficult to manage
- Under pressure from business groups
- Lack of sufficient competent resources
- Lack of process culture
- IT not aligned to perform diligent security work

• Challenges Of InfoSec:

- Silos & lack of coherent ownership
- Lot of time & energy wasted in traversing dept boundaries
- Enabling environment for tough security work missing
- Security hardening glaringly absent

Role Of Regulator In Cyber Security:

- Regulations, guidelines, and audit
- Engagement of key stakeholders

- Technical and industry expertise
- Regional and international cooperation

Pakistan cyber security posture (industry):

- Superficial security
- Reactive
- Emphasis on governance
- Security hardening of IT assets largely absent
- Industry has been in denial for last decade

Solution For InfoSec Improvement (PK)

- Generally, Pakistan Information Security is **one generation behind** IT deployment
- **Four-layer security** transformation model provides **the correct sequence** and focus in order to address organizational security gaps

Major Component used in typical Enterprise IT Network *(Is mains se mostly switches pouchte hain jo highlight keye hain)*

- Edge router
- NGN FW
- DMZ:
 - Web security GW/Proxy
 - Application security FW
 - Web server
 - Email antispam GW
- IPS & N-DL
- **Distribution switch**
- **Data center switch & FW**
- **Access switch**
- NAC
- SOC:
 - SIEM
 - VM
 - Other SOC tools
- System AV
- Server HIPS
- UTM
- Mobile device – MDM
- **Typical security tools used in an enterprise:**
 - Enterprise antivirus
 - MS Active Directory (AD)

- Vulnerability manager
- Logs management
- Network & performance
- monitoringAutomated backups

- **Virtualization security classified into three areas: Most Imp**

- Architectural
- Hypervisor software Configuration

- **Performance KPIs:**

- Minimal network disruption
- Timely completion of new projects
- Quick and efficient changes to existing applications (change-requests) to meet business requirements

- **Security posture:**

- Surprisingly **in 95% of all orgs in Pakistan** (all types and sizes), security posture has been found to be deficient
- Lack of awareness in the country has contributed to this **deficient and poor security** posture

1. **Block unauthorized traffic at edge** (direct public www traffic to DMZ web server)
2. **Edge malware** protection & DMZ
3. Web & email are important vectors to secure against malware and attacks
4. NGN-FW (may be found in a UTM as well)
5. Web security GW and email anti-spam GW solutions
6. Granular **access list filtering** in edge and data center FWs (source, destination, and traffic type/port)
7. A good AV solution, **and keep virus definitions** updated
8. **Monthly VM scans**

Write the Names of Common SIEM solution for security Event detection?

ANSWER:

- A. LogRhythm
- B. IBM Q-Radar
- C. Splunk
- D. Elastic search

20 Cis controls are most Important: is main se kisi 10 k name yad ker lena lazmi

CSC5-I: Controlled Use Of Administrative Privileges

CIS Controls

- 1: Inventory of Authorized and Unauthorized Devices →
- 2: Inventory of Authorized and Unauthorized Software →
- 3: Secure Configurations for Hardware and Software →
- 4: Continuous Vulnerability Assessment and Remediation →
- 5: Controlled Use of Administrative Privileges →
- 6: Maintenance, Monitoring, and Analysis of Audit Logs →
- 7: Email and Web Browser Protections →
- 8: Malware Defenses →
- 9: Limitation and Control of Network Ports →
- 10: Data Recovery Capability →
- 11: Secure Configurations for Network Devices →
- 12: Boundary Defense →
- 13: Data Protection →
- 14: Controlled Access Based on the Need to Know →
- 15: Wireless Access Control →
- 16: Account Monitoring and Control →
- 17: Security Skills Assessment and Appropriate Training to Fill Gaps →
- 18: Application Software Security →
- 19: Incident Response and Management →
- 20: Penetration Tests and Red Team Exercises →

- **What is high availability (HA) ?**

- High availability of a system or component assures a high level of operational performance(uptime) for a given period of time

: Info security Governance Block.

Initial

- Policy
- Responsibility
- Recourse and priority
- Periodic review

Intermediate

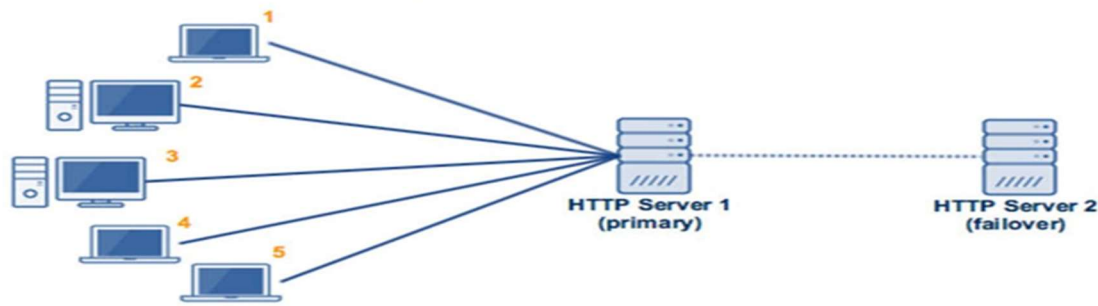
- Change management
- SOP,s
- Awareness Monitoring

Mature

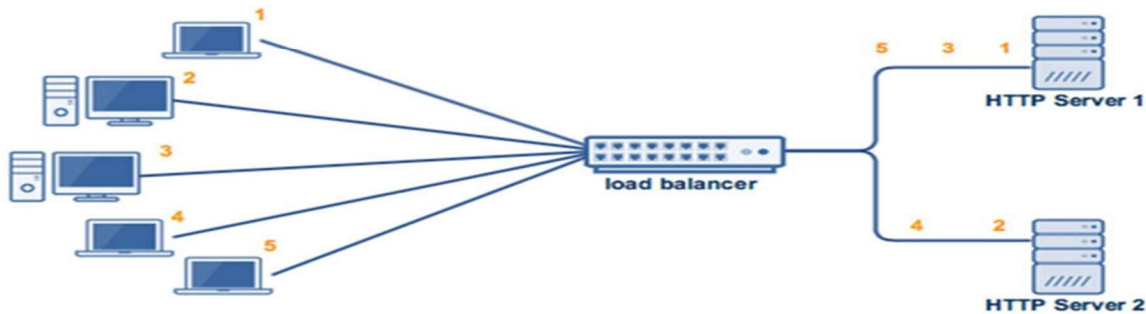
- Risk management
- Internal audit
- Incident management

Very very imp: systems configuration active active and active standby:

ACTIVE-STANDBY SERVER CONFIGURATION



ACTIVE-ACTIVE SERVER CONFIGURATION



Three types of redundant site models:

- Hot site (is Expensive)
- Cold site (is Cheapest)
- Warm site (Middle Ground)

Backup strategy:

- Primary backup at secondary DR site
- Mirror at DR site
- **For critical systems:** monthly full backup, daily incremental backup
- **For critical network devices:** weekly full backup; backups based on change

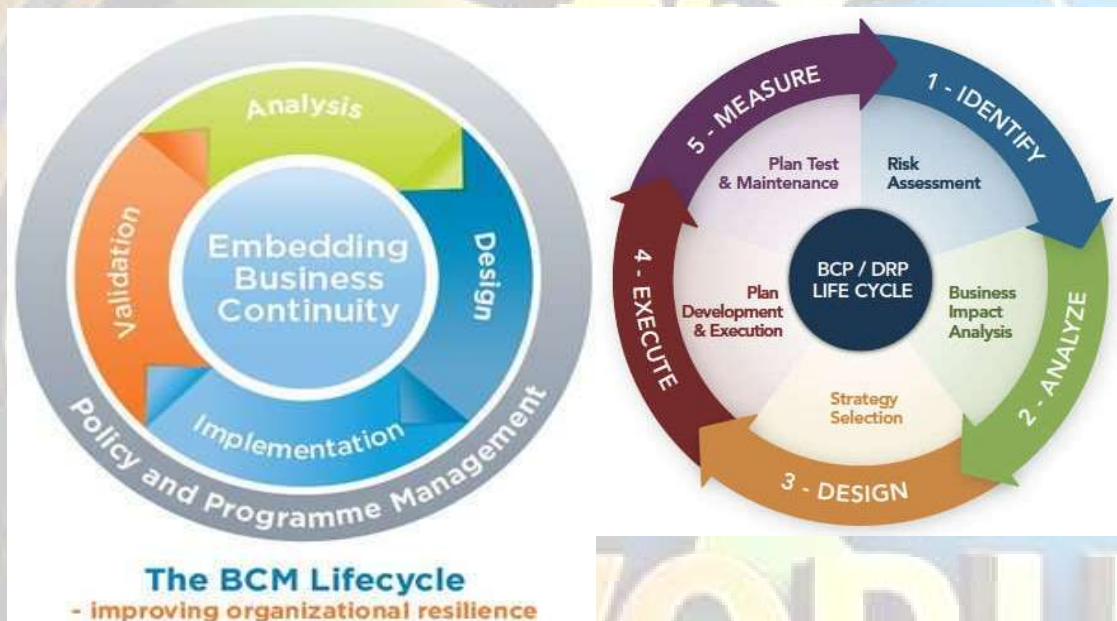
- **Backup considerations:**

- What to backup?
- Backup location?
- Freq of backup?
- Backup operator?
- Backup checker (verification)?
- Backup test & security methods?
- Technology & tools used for backup?

- **What is a disaster?**

- Any significant event that causes disruption of information technology processing facilities, thus affecting the operations of the business

- **What is disaster recovery (DR)?**
 - DR is an area of security that allows an organization to maintain or quickly resume mission-critical (IT) functions following a disaster
- **What could cause the invocation of a DR fail over to DR site?**
 - Natural disasters such as flood, earthquake, lightning, storm
 - Disaster caused by human actions such as riot, fire, terrorist act, etc
- **What is business continuity?**
 - Business Continuity (BC) is the capability of the org to continue delivery of products or services at acceptable predefined levels following a disruptive incident (*Source: ISO 22301:2012*)



SSH Protocols:

SSH mean secure shell protocols

Description: SSH supports 2 different and incompatible protocols:

SSH1 and SSH2.

SSH1 was the original protocol & was subject to security issues.

SSH2 is more advanced and secure.

NHS Hospital Attack: (Is main just attack ki type pouchi jaye gi. Ransomware)

NHS hack using wanna descriptor Ransomware has shut down IT system over 75,000 attacks over 99 countries

- What is a BC plan?

- A document that consists of critical information an organization needs to continue operating during an unplanned event
- The BCP should state essential functions of the business, identify which systems and processes must be sustained, & detail how to maintain them.

IT Assets life cycle diagram. Remembers all steps



- Patching:

- Fixing vulnerabilities (which may be exploited by malware or attackers) in software or firmware with vendor released patches (auto or manual updates)
- Patches are also called fixes

Topic no 57: Pre-requisites For Security Hardening

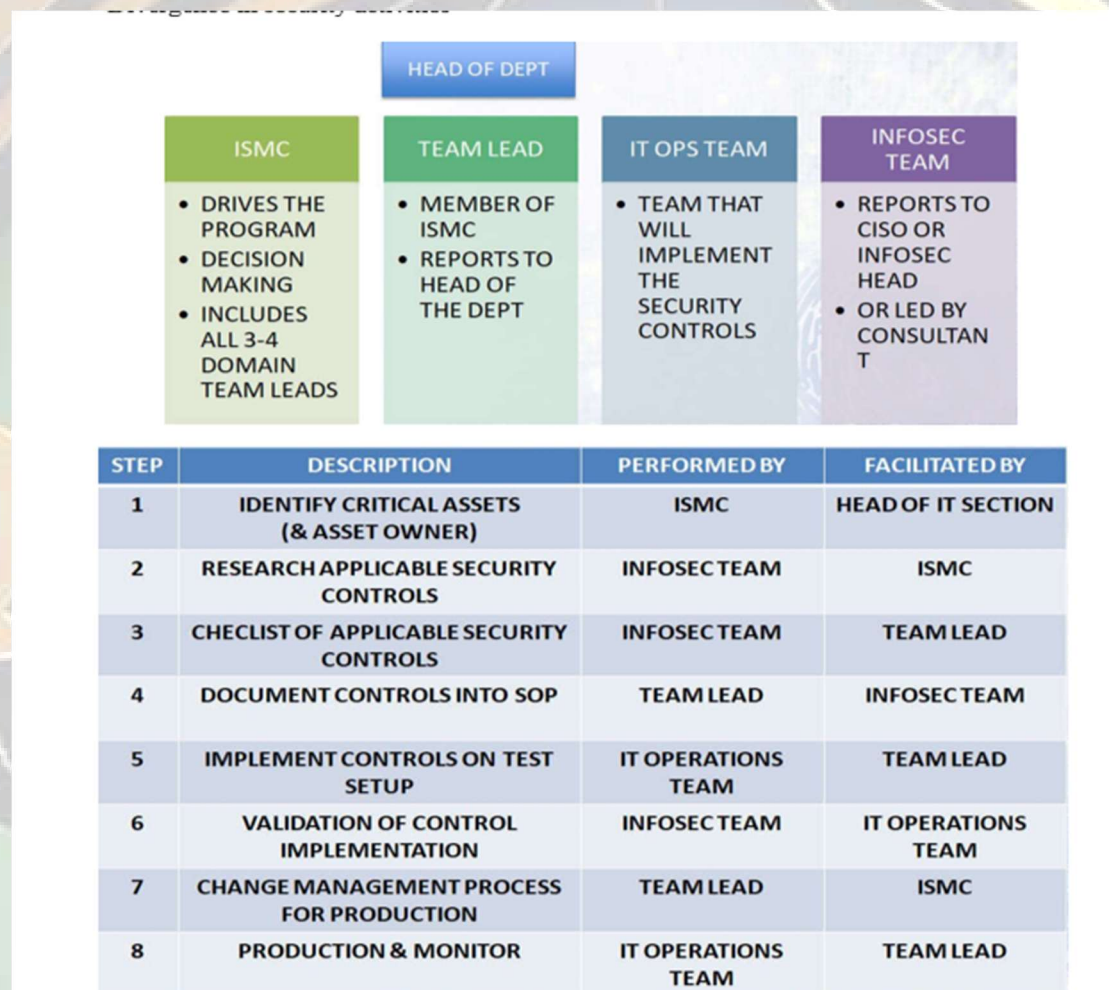
1. Security program approved
2. Consultant on board
3. Project kick-off meeting held
4. ISMC team identified and their loading for this project communicated
5. Appraisal linkage of core resources announced by CIO

Topic no 58: Who Will Conduct The Security Hardening? (very imp yeh table shape main bhe a sakta hai)

- **Involvement of various stakeholders for security hardening**
 - Operations teams (apply control, study control)
 - Security team (Conduct validation, checklist control, document control)
 - IT management (sign off on change management, ensure It ops team receive

- required guidance and support)
- Consultant
- Business

Topic no 59: 8 Step Methodology – Security Hardening (8 step methodology detail in table)



CIS Controls :

In main se kisi ka bhe pouch sakte hain like Mobile devices main kitne controls hain ap ne kehna hai 8. Print devices main 1 control hai. Cloud providers main 2 controls hain. Total 107 hai.

#	OVERALL CIS BENCHMARK CATEGORIES	TOTAL
1	OPERATING SYSTEMS	36
2	SERVER SOFTWARE	33
3	CLOUD PROVIDERS	2
4	MOBILE DEVICES	8
5	NETWORK DEVICES	6
6	DESKTOP SOFTWARE	21
7	MULTIFUNCTION PRINT DEVICES	1
	GRAND TOTAL CIS BENCHMARKS	107

A Look At CIS Security Benchmarks (3)

Audit:

- Step 1: Run the following command to show what the console timeout is set to

```
hostname#sh run console | in timeout.5
```

The output should look like

```
console timeout 5
```

Example:

```
Asa-fw#sh run console | in timeout.5
console timeout 5
```

Here the session timeout is 5 minutes

CIS Microsoft Windows Server 2012 R2 Benchmark

v2.2.1 - 01-31-2017

- Profile applicability:
 - Level 1 domain controller
 - Level 1 member server

- Level 2 domain controller
- Level 2 member server

Topic no 66: A Look At DISA STIGs (1)

- USA DoD
- Security Technical Implementation Guides (STIGs)
- Most expansive security benchmarks available
- Most regularly updated
- Unclassified version
- **STIG content:**
 - General information (title)
 - Discussion
 - Check content
 - Fix text
 - CCI (References)

This question will be in form of table: (It will misalign u have to rewrite according to this)

SEVERITY	DISA CATEGORY CODE GUIDELINES
CAT 1	Any vulnerability, the exploitation of which will directly and immediately result in loss of Confidentiality, Availability, or Integrity.
CAT 2	Any vulnerability, the exploitation of which has a potential to result in loss of Confidentiality, Availability, or Integrity.
CAT 3	Any vulnerability, the existence of which degrades measures to protect against loss of Confidentiality, Availability, or Integrity

CIS and DISA comparison table: u have to arrange this also too

FEATURE	CIS	DISA
CONTROL COVERAGE	GOOD	EXCELLENT
ORG SUITABILITY	SMALL AND MEDIUM ORGS	LARGE ORGS
USER FRIENDLINESS	GOOD	SATISFACTORY
UNUSABLE TERMINOLOGY	NO	YES
CONTROL DETAIL TOOLS	GOOD CAT (COMMERCIAL)	SATISFACTORY SCAP (MILITARY USE)

FEATURE	CIS	DISA
CONTROL PRIORITIZATION	LEVEL 1, LEVEL 2	CAT I - CAT III
TRACKING EASE	CAT TOOL (COMMERCIAL)	FREE STIG VIEWER (CHECKLIST)
FREQUENCY OF UPDATES	FAIR	QUARTERLY
INDUSTRY CREDIBILITY	HIGH	VERY HIGH
INDUSTRY ADOPTION	HIGH	MODERATE

- Profile applicability:

CIS Red Hat Enterprise Linux 7 Benchmark

v2.1.1 - 01-31-2017

- Level 1, Server
- Level 1, Workstation

grep "^Protocol" /etc/ssh/sshd_config Protocol 2

Topic no 73: Security Hardening – Case Study – Solaris

- **Severity:** CAT I
- Profile applicability:
- Level 2

Topic no 75: Security Hardening – Case Study – Oracle

- **Severity:** CAT I
- The service name format is: **Oracle[ORACLE_HOME_NAME]TNSListener**

Topic no 76: Case Study Security Hardening – MS SQL

- *Ensure 'sa' Login Account has been renamed (Scored)*
- Profile applicability: Level 1 database engine

Topic no 78: Case Study Security Hardening – Windows 8

- Profile applicability:
 - Level 1
 - Level 1 + BitLocker

Topic no 79: Case Study Security Hardening – Win 10

- **Severity:** CAT I

Topic no 80: Case Study Security Hardening – MS Exchange

- Profile applicability:
 - **Level 1** - Mailbox Services Security
 - **Default Value:** False

Topic No 83: Security Hardening – Case Study - Chrome

- General Information:
 - **Rule Title :** Session only based cookies must be disabled.
- General Information:
- **Vuln ID:** V-44799
 - **STIG ID:** DTBC-0045
 - **Severity:** CAT I

Topic No 84: Case Study Security Hardening – Firefox

- Profile applicability:
 - Level 2

Topic No 87: Case Study Security Hardening – Cisco IOS 15

- 3.3.2.2 Set 'ip ospf message-digest-key md5' (Scored)
- Profile applicability:
 - Level 2
 - **Default Value:** Not set

Topic No 88: Security Hardening – Case Study – WLAN

- **Severity:** CAT II

Topic no 91 & 92 : Software Security Fundamentals-SAMM:



- **OWASP Software Assurance Maturity Model (SAMM) Governance Phase:**
 - Strategy & Metrics
 - Education & Guidance
 - Policy & Compliance
- **OWASP Software Assurance Maturity Model (SAMM) Construction Phase:**
 - Security Requirements
 - Threat Assessment
 - Secure Architecture

Topic no 94: SECURITY HARDENING – SOFTWARE APPLICATIONS

- **Two types of security hardening:**
 - IT assets (systems, network devices, databases, applications)
 - Software developed internally or by third party
- **Typical enterprise software:**
 - ERP (Oracle, SAP, IBM, etc)

Internally or 3rd party developed software in ASP.NET, PHP, Android/IOS, or other platform

Topic no 103: Case Study Security Hardening – Android

- *1.15 Ensure Android Device Manager is set to Enabled (Not Scored)*
- Profile applicability:
 - Level 2

Topic no 104: Case Study Security Hardening – Apple IOS 10

Profile applicability:

Level 2 - Institutionally Owned Device

Case Study Security Hardening – Cloud AWS

Profile applicability: – Level 2

What type of assets do not have a CIS/DISA STIG?

Ans:

- Software applications (ASP.NET, PHP, Other)
- Other applications such as asterisk deployments

CIS benchmark in profile applicability

- Profile applicability (ASA 8.X, ASA 9.X)
- Description – Rationale – Audit – Remediation – Default value – References

Question: Mention the name of frame work against which nessus scanner gives configuration auditing feature? Answer:

- Configuration auditing: CERT, CIS, COBIT/ITIL, DISA STIGs, FDCC, ISO, NIST,

Question: Write the First step in automated Security hardening and validation name of tool Used?

Answer:

Step 1: Scan an IT asset using Qualys compliance scan, NESSUS compliance scan, or CIS CAT PRO Tool

Ques on: As a Security Analyst, you are tasked with investigating a large-scale cyber-attack that severely disrupted healthcare services. The attack targeted several healthcare organizations, including the UK's National Health Service (NHS), which resulted in widespread system failures. Critical patient data, such as medical records, was encrypted, leaving hospitals unable to access important information. The disruption affected more than 99 countries, causing delays in surgeries, appointments, and medical treatments. The attackers used a vulnerability in outdated software, and the attack spread rapidly across networks. Hospitals were forced to rely on manual systems for patient care, which led to significant challenges. What type of cyber-attack occurred in this scenario? Just write the name

Ans: Ransomware attack

MCQ file M. Qasim Ali 03337435091 U tube qasim Khan world for videos

Question: A critical security measure in Solaris Server hardening is

- A. running all services as root
- B. keeping default permissions for shell files
- C. setting shell file permissions to 0755 or less**
- D. allowing public access to system logs

Question: The primary security concern when hardening VMware environments is

- A. physical access to servers
- B. misconfigured virtual networking and permissions**
- C. lack of anti-virus software
- D. overuse of cloud storage

Question: Security hardening in Windows Server 2012 R2 requires disabling code execution. to prevent unauthorized

- A. user Account Control**

- B. Windows Defender
- C. autoplay for all drives**
- D. windows Firewall

Question: The key factor for driving a successful information security transformation is

- A. implementing security policies without board approval
- B. Adopting a reactive security strategy
- C. strong executive sponsorship and commitment**
- D. keeping security transformation as an isolated IT project

Question: Disaster Recovery (DR) is primarily concerned with

- A. restoring IT services after an unexpected incident**
- B. preventing security updates from being applied
- C. eliminating the need for backup systems
- D. only focusing on physical security threats

Question: Backup strategies help organizations to

- A. reduce the need for security measures
- B. Store all critical data on a single drive
- C. recover data in case of failures or cyber incidents**
- D. avoid using redundant storage solutions

Question:is an example of an information security risk.

- A. Installing an updated security patch
- B. An employee accidentally sharing confidential company data**
- C. Regular system backups
- D. Using strong passwords

Question: One of the prerequisites for a security hardening program is

- A. eliminating third-party software from the system
- B. Defining and documenting a Minimum-Security Baseline (MSB)**
- C. ensuring no software updates are installed
- D. Avoiding collaboration with compliance teams

Question: According to Rule 01 in C++ Applications Security Hardening.

aspect is emphasized.

- A. concurrency
- B. expressions

C. declarations and initialization

D. memory management

Question: SSH Protocol 2 provides that SSH Protocol 1 lacks.

A. faster connection speed.

B. more secure and advanced encryption.

C. better file transfer capabilities.

D. compatibility with older systems.

Question: "Hot site" in disaster recovery is a

A. backup site that stores data but requires setup time

B. fully functional, mirrored site that runs concurrently with the primary data center

C. Minimal site with no equipment installed, ready to receive data

D. site used for testing new applications

Question: can prevent unauthorized access to a data center.

A. VPN gateway

B. Data Center Firewall (FW)

C. Access Point

D. Email Security Gateway

Question: Primary reason for using mutex objects is to

A. speed up execution

B. protect shared data from concurrent access

C. enhance memory capacity

D. facilitate error handling

Question: is not a key function of IT security.

A. Mobile security

B. Application and database security

C. Financial auditing

D. Network security

Q: Which of the following is not pillar of information security.

Ans: Piilars yeh hain is k elawa jawab ho ga. (confidentiality , integrity availability)

Q; effective meaning of security program Mean

in simpler terms just means effective management of the security program

Ans: Information security governance

Q: For more securing the window 10 which of need to be something like that.

Ans: Disabled (I think So)

Q: Which one is first step of information security life cycle.

Ans: Identify critical assets

Q: Which one is not CIS benchmark

Ans: Window xp.

What type of assets do not have a CIS/DISA STIG?

Ans: – Software applications (ASP.NET, PHP, Other) – Other applications such as asterisk deployment

Q: There are two types of SSH protocol the SSH2 protocol has following features.

Ans: More advance and more secure

Q: High availability ki working batani thi

Ans : High availability of a system or component assures a high level of operational performance (uptime) for a given period of time

Q: Disaster recovery kia hota h ye batana tha mcqs k through

DR is an area of security that allows an organization to maintain or quickly resume mission critical (IT) functions following a disaster

Q: ISMC ki abbreviation batani thi.

Ans: Information security management committee

Q: if company gets failed to achieve Information security what will be the consequences.

Ans: Correct option: security breach and data loss

Q: What is the speedy way to recover ur data?

Ans: A -A. local storage , B: online, Offline D, Cloud Stronge

Q: responsible for implementing information security program

Ans: Heads department

Q: What is information security awareness

Ans: The importance of protecting sensitive information

- What they should do to handle information securely
- Risks of mishandling information

Q: on Which basis Data is to be back up

Ans : On the criticality of the data

1. **An attack in which attacker alter the system resources is called -----?**
A. **Active attack**
B. Passive attack
C. Direct attack
D. Indirect attack
2. **Students are not Allowed to bring cell phone in the exam hall is example of-----?**
A. **Security Policy**
B. Security control
C. Security mechanism
D. Security service
3. **----- are three pillars of information security security?**
ANS: **confidentiality, integrity, availability.**
4. **Ransomware is _____ ?**
Ans: **a type of attack that encrypt data on computer and servers.**
5. **NESSUS tool is used at _____ layer in information security transformation framework?**
A. Sec governance
B. Sec engineering
C. **Vulnerability management.**
D. Sec hardening
6. **_____ mean effective management of security program ?**
A. **Sec governance**
B. Sec engineering
C. Vulnerability management.
D. Sec hardening
7. **Which of the following will be considered the most specific standard/ framework applicable only to specific type of industry?**
A. ISO27002.2013
B. COBIT
C. **PCI.DSS**
D. ISO27001.2013

8. Which of the following may be applied to any type of industry in which information technology is being used?

- A. ISO27002.2013
- B. COBIT, and ISMS
- C. COBIT, ISMS, PCI
- D. PCI, DSS, ISMS

9. ____ are challenges of information security?

- A. Lack of budget and insufficient recourse allocation
- B. Highly specialized and continuously changing technology
- C. Cloud and IOT
- D. lack of owner ship, department silos, missing security hardening (I think D, may be A)

10. There are ____ main steps in information security life cycle

- A. 6
- B. 7
- C. 9
- D. 11

11. Regionally the most well developed cyber security strategy and framework

Developed by Malaysia is at rank _____?

- A. 1
- B. 2
- C. 3
- D. 4

12. ____ is prevention of the unauthorized use of a resource?

- A. Access control
- B. Data integrity
- C. non-repudiation
- D. availability

13. The next generation firewall should be placed at _____?

- A. Inside the data center

B. Where it is physically secure

C. Inside the DMZ

D. **At the network perimeter and at the entrance to the data center**

14: Major security function performed by the perimeter NGN fire wall are ____?

A. Web sec and email sec.

B. Malware filtering, access list for traffic filtering bandwidth filtering

C. Wan interface

D. **APPT attack prevention**

15. The key challenges with mobile technology is that _____NGN?

A. It is leading to wastage of time and distraction

B. **Traditional enterprise security perimeter boundary has disappeared.**

C. Location of the user can be tracked

D. Apps on mobile device may be Trojans.

16. The recommended manners to protect sensitive data with a VM is to?

A. Encrypt data stored on workstation

B. **Encrypted stored on virtual and cloud servers.**

C. Encrypt data stored on USB

D. Encrypt data stored file servers

17. One of the main challenge in small sized organization related to security is ____?

A. Lack of good data center

B. **Lack of budget and resources allocate for security.**

C. Lack of security vendor

D. Lack of security devices

18. At which point a malicious entity/ black hat hackers attack for website defacement in an IT network ____?

A. Edge router or edge firewall

B. **Web server in DMZ**

- C. Email gate way
- D. Data center switch

19. How web and email can be secured against malware and attacks in and Enterprise IT network?

- A. BY blocking unauthorized traffic at edge
- B. By keeping a good and updated solution
- C. By using web security an email antispam gateway
- D. By using malware protection at edge.

20. _____ are the main phases/steps in a business continuity life cycle.

- A. analysis, design, implement and validate
- B. identity, analyze, design, execute
- C. Identity, analyze, design, execute, measure,
- D. Analyze, implementation and validate

21. _____ enterprises have their own vulnerability scanner ?

- A. 90%
- B. 75%
- C. 50%
- D. 5%

22. _____ project sequence is followed in information projects.

- A. Establish track, implement across IT
- B. Pilot, implement across IT, continuous improvement.
- C. Establish track, MSB, pilot, implement across IT, continuous improvement
- D. Establish track, MSB, implement across IT

23. _____ category has maximum number of CIS benchmark

- A. Operating system
- B. Mobile device.

C. network device.

D. Cloud providers

24. _____ category has minimum number of CIS benchmark

A. Multifunction print device.

B. mobile device

C. network device.

D. Cloud provider

25. What does audit explain about control in CIS benchmark?

A. Describe the control

B. Describe the benefit

C. Tells how to check the controls.

D. Tells how to apply controls

26. According to applicability CIS device control in _____ category?

A. Level1 and level 2

B. Scored and un scored.

C. Cat1 , Cat2, Cat3

D. High critical, low critical

27. Frequency of updating the signature file for antivirus program must be set to ____?

A. Daily basis

B. weekly basis

C. fortnightly basis

D. Monthly basis

28. The direct console user interface should be _____ ?

A. Disable

B. Enable

C. Partially enabled

D. Monitored

29. A program or device that can monitor data traveling over a network is called_____ ?

A. Hoax

B. Router

C. **Sniffer** (Conform from google)

D. Spoof

30. Internationalized domain name are displayed as

A. Little ENDIAN

B. Big ENDIAN

C. UTF-32

D. **UNICODE**

31. Information security is combination of _____?

ANS: **People process and technology**

32. Under which category of CIS benchmark MS window servers fall?

A. server software

B. Mobile device

C. **Operating system**

D. Cloud providers

33. OWASP, cloud security alliance, ISACA and ISC2 are example of _____?

A. Cyber security government organization

B. **cyber security professional associations**

C. Research organization

D. International security operations

34. MS Exchange serve falls under _____ category of CIS benchmark.

A. Operating system

B. server software

C. Desktop software

D. Cloud providers

35. What is the function of active directory AD in an enterprise network?

A. Pushing out security policies through GPO

B. Windows update and configurations

C. Log collection and analysis

D. Network operation and performance. management

36. DISA gives us the following feature set as compared to CIS

A. Excellent control coverage with some useable terminology

B. User friendly and for small/medium size organization

C. Good control with no unusable terminology

D. Cat tool to check the compliance with standard

37. N+1 redundancy pattern is sometimes referred As_____?

A. High Availability

B. parallel redundancy

C. active- passive

D. Active Active

38. The best model in Pakistan to effectively address the weakness in the cyber security is to adopt_____?

A. ISMS

B. Four layer security transformation

C. COBIT

D. CIS security benchmarks

39. _____ is technique used to gain unauthorized access to computer, wherein the intruder send messages with a source IP address that has been forged to indicate that the messages are coming from a trusted source?

A. Man in middle

B. Denial of the service

C. Zombie

D. Spoofing

40. The key and most important element in the management process is ____-?

- A. Risk documentation
- B. Risk determination
- C. Risk assessment
- D. Risk policy

41. _____ is the first layer in the information security transformation framework?

- A. Security governance
- B. security engineering
- C. Vulnerability management
- D. Security hardening

42. Purpose of SIEM solution is _____?

- A. Malware filtering, access list for traffic filtering, bandwidth filtering
- B. Log aggregation, security events dashboard, event correlation and root cause analysis
- C. Log collection
- D. Malicious traffic detection

43. _____ are four layers of transformation model in sequence?

Ans: Security hardening, vulnerability management, security engineering, security governance

44. Surprisingly in _____ of all organization in Pakistan (All type) security posture has been found to be deficient.

- A. 80%
- B. 85%
- C. 90%
- D. 95%

45. If a system enters into _____ state, it is a security violation.

- A. initial
- B. Final
- C. Secure
- D. Unsecure